

Passwd, Shadow & Opasswd

Linux-based distributions can use many different authentication mechanisms. One of the most commonly used and standard mechanisms is [Pluggable Authentication Modules \(PAM\)](#). The modules used for this are called `pam_unix.so` or `pam_unix2.so` and are located in `/usr/lib/x86_64-linux-gnu/security/` in Debian based distributions. These modules manage user information, authentication, sessions, current passwords, and old passwords. For example, if we want to change the password of our account on the Linux system with `passwd`, PAM is called, which takes the appropriate precautions and stores and handles the information accordingly.

The `pam_unix.so` standard module for management uses standardized API calls from the system libraries and files to update the account information. The standard files that are read, managed, and updated are `/etc/passwd` and `/etc/shadow`. PAM also has many other service modules, such as LDAP, mount, or Kerberos.

Passwd File

The `/etc/passwd` file contains information about every existing user on the system and can be read by all users and services. Each entry in the `/etc/passwd` file identifies a user on the system. Each entry has seven fields containing a form of a database with information about the particular user, where a colon (`:`) separates the information. Accordingly, such an entry may look something like this:

Passwd Format

```
cry0l1t3 : x : 1000 : 1000 : cry0l1t3,,, : /home/cry0l1t3 : /bin/bash
```

Login name	Password info	UID	GUID	Full name/comments	Home directory	Shell
------------	---------------	-----	------	--------------------	----------------	-------

The most interesting field for us is the Password information field in this section because there can be different entries here. One of the rarest cases that we may find only on very old systems is the hash of the encrypted password in this field. Modern systems have the hash values stored in the `/etc/shadow` file, which we will come back to later. Nevertheless, `/etc/passwd` is readable system-wide, giving attackers the possibility to crack the passwords if hashes are stored here.

Usually, we find the value `x` in this field, which means that the passwords are stored in an encrypted form in the `/etc/shadow` file. However, it can also be that the `/etc/passwd` file is writeable by mistake. This would allow us to clear this field for the user `root` so that the password info field is empty. This will cause the system not to send a password prompt when a user tries to log in as `root`.

Editing /etc/passwd - Before

Passwd, Shadow & Opasswd
root:x:0:0:root:/root:/bin/bash

Editing /etc/passwd - After

Passwd, Shadow & Opasswd
root::0:0:root:/root:/bin/bash

```

[eu-academy-3]-[10.10.14.16]-[htb-ac-819475@htb-upwr9gdxtm]-[~]
[★]$ 

```

Passwd, Shadow & Opasswd
<pre> [cry0l1t3@parrot]-[~]\$ head -n 1 /etc/passwd root::0:0:root:/root:/bin/bash [cry0l1t3@parrot]-[~]\$ su [root@parrot]-[/home/cry0l1t3]# </pre>

Even though the cases shown will rarely occur, we should still pay attention and watch for security gaps because there are applications that require us to set specific permissions for entire folders. If the administrator has little experience with Linux or the applications and their dependencies, the administrator may give write permissions to the `/etc` directory and forget to correct them.

Shadow File

Since reading the password hash values can put the entire system in danger, the file `/etc/shadow` was developed, which has a similar format to `/etc/passwd` but is only responsible for passwords and their management. It contains all the password information for the created users. For example, if there is no entry in the `/etc/shadow` file for a user in `/etc/passwd`, the user is considered invalid. The `/etc/shadow` file is also only readable by users who have administrator rights. The format of this file is divided into **nine fields**:

Shadow Format

cry0l1t3	:	\$6\$wBRzy\$...SNIP...x9cDWUxW1	:	18937	:	0	:	99999	:	7	:	:	:	:
Username	Encrypted password			Last PW change	Min. PW age	Max. PW age	Warning period	Inactivity period	Expiration date	U				

Shadow File

```

[eu-academy-3]-[10.10.14.16]-[htb-ac-819475@htb-upwr9gdxtm]-[~]
[★]$ 

```

Passwd, Shadow & Opasswd
<pre> [cry0l1t3@parrot]-[~]\$ sudo cat /etc/shadow root:*:18747:0:99999:7::: sys:!:18747:0:99999:7::: ...SNIP... cry0l1t3:\$6\$wBRzy\$...SNIP...x9cDWUxW1:18937:0:99999:7::: </pre>

If the password field contains a character, such as `!` or `*`, the user cannot log in with a Unix password. However, other authentication methods for logging in, such as Kerberos or key-based authentication, can still be used. The same case applies if the **encrypted password** field is empty. This means that no password is required for the login. However, it can lead to specific programs denying access to functions. The **encrypted password** also has a particular format by which we can also find out some information:

- `$<type>$<salt>$<hashed>`

As we can see here, the encrypted passwords are divided into three parts. The types of encryption allow us to distinguish between the following:

Algorithm Types

- `e1e` - MD5

Integrated Terminal

- **\$2y\$** - Eksblowfish
- **\$5\$** - SHA-256
- **\$6\$** - SHA-512

By default, the SHA-512 (**\$6\$**) encryption method is used on the latest Linux distributions. We will also find the other encryption methods that we can then try to crack on older systems. We will discuss how the cracking works in a bit.

Opasswd

The PAM library (**pam_unix.so**) can prevent reusing old passwords. The file where old passwords are stored is the **/etc/security/opasswd**. Administrator/root permissions are also required to read the file if the permissions for this file have not been changed manually.

Reading /etc/security/opasswd

Passwd, Shadow & Opasswd

```
dbcypth0n@htb[/htb]$ sudo cat /etc/security/opasswd  
cry0l1t3:1000:2:$1$HjFAfYTG$qNDkF0zJ3v8yLC0rKB0kt0,$1$kcUjWZJX$E9uMSmiQeRh4pAAgzuvkq1
```

Looking at the contents of this file, we can see that it contains several entries for the user **cry0l1t3**, separated by a comma (,). Another critical point to pay attention to is the hashing type that has been used. This is because the **MD5 (\$1\$)** algorithm is much easier to crack than SHA-512. This is especially important for identifying old passwords and maybe even their pattern because they are often used across several services or applications. We increase the probability of guessing the correct password many times over based on its pattern.

Cracking Linux Credentials

Once we have collected some hashes, we can try to crack them in different ways to get the passwords in cleartext.

Unshadow

Passwd, Shadow & Opasswd

```
dbcypth0n@htb[/htb]$ sudo cp /etc/passwd /tmp/passwd.bak  
dbcypth0n@htb[/htb]$ sudo cp /etc/shadow /tmp/shadow.bak  
dbcypth0n@htb[/htb]$ unshadow /tmp/passwd.bak /tmp/shadow.bak > /tmp/unshadowed.hashes
```

Hashcat - Cracking Unshadowed Hashes

Passwd, Shadow & Opasswd

```
dbcypth0n@htb[/htb]$ hashcat -m 1800 -a 0 /tmp/unshadowed.hashes rockyou.txt -o /tmp/unshadowed.cracked
```

Hashcat - Cracking MD5 Hashes

Passwd, Shadow & Opasswd

```
dbcypth0n@htb[/htb]$ cat md5-hashes.list
```

Integrated Terminal

Passwd, Shadow & Opasswd

```
dbcyp0n@htb[/htb]$ hashcat -m 500 -a 0 md5-hashes.list rockyou.txt
```

VPN Servers

Warning: Each time you "Switch", your connection keys are regenerated and you must re-download your VPN connection file.

All VM instances associated with the old VPN Server will be terminated when switching to a new VPN server.

Existing PwnBox instances will automatically switch to the new VPN server.

EU Academy 3

Low Load

PROTOCOL

☒ UDP 1337 ☐ TCP 443

[DOWNLOAD VPN CONNECTION FILE](#)
**Connect to Pwnbox**

Your own web-based Parrot Linux instance to play our labs.

Pwnbox Location

AU

60ms

Terminate Pwnbox to switch location

```
Applications Places System Thu Aug 22, 23:31 will@
File Edit View Search Terminal Tabs Help
will@nix01: ~/.backups
will@nix01:/home/kira/.mozilla/firefox/ytb95ytb.default-release$ cd /home/will
will@nix01:~$ ls
will@nix01:~$ ls -la
total 28
drwxr-xr-x 3 will will 4096 Feb  9 2022 .
drwxr-xr-x 5 root root 4096 Feb  9 2022 ..
drwxrwxr-x 2 will will 4096 Feb  9 2022 .backups
-rw----- 1 will will  81 Feb  9 2022 .bash_history
-rw-r--r-- 1 will will 220 Feb 25 2020 .bash_logout
-rw-r--r-- 1 will will 3771 Feb 25 2020 .bashrc
-rw-r--r-- 1 will will 807 Feb 25 2020 .profile
will@nix01:~$ cat .bash_history
cd
mkdir .backups
cd
ls -la
tree .
tree ...
ls -la
```

Integrated Terminal

Life Left: 83m

+



Questions

Answer the question(s) below to complete this Section and earn cubes!

Target(s): 10.129.202.64 (ACADEMY-PWATTACKS-NIX01)

Life Left: 90 minute(s)

+

Terminate X

Cheat Sheet

Download VPN
Connection File

+ 0

 Examine the target using the credentials from the user Will and find out the password of the "root" user. Then, submit the password as the answer.

Submit your answer here...

+10 Streak pts

Submit

Show Solution

Previous

Next

Cheat Sheet

Resources

? Go to Questions

Table of Contents

Introduction

Theory of Protection	
Credential Storage	
John The Ripper	

Remote Password Attacks

Network Services	
Password Mutations	
Password Reuse / Default Passwords	

Windows Local Password Attacks

Attacking SAM	
Attacking LSASS	
Attacking Active Directory & NTDS.dit	
Credential Hunting in Windows	

Linux Local Password Attacks

Credential Hunting in Linux	
Passwd, Shadow & Opasswd	

Integrated Terminal

-  Pass the Hash (PtH)
-  Pass the Ticket (PtT) from Windows
-  Pass the Ticket (PtT) from Linux

Cracking Files

-  Protected Files
-  Protected Archives

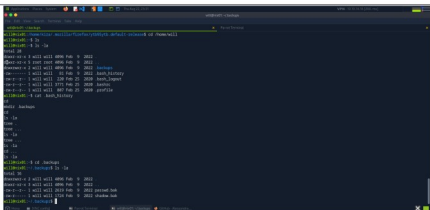
Password Management

- Password Policies
- Password Managers

Skills Assessment

-  Password Attacks Lab - Easy
-  Password Attacks Lab - Medium
-  Password Attacks Lab - Hard

My Workstation



   Life Left: 83m 